



CONTROLLED DRAFT

Security, Threat Model & Cryptography Specification

Security controls for discovery, pairing, local identity and content transfer

Product	Nod
Document version	1.0
Date	19 September 2026
Owner / operator	[NOD OWNER / LEGAL ENTITY]
Status	Controlled Draft

Release note: This pack is a production-ready baseline. Bracketed operator details must be completed before public release. Legal documents should be reviewed by Nigerian counsel before publication or execution.

1. Security objectives

- Confidentiality of local profile and transferred content.
- Integrity of completed transfers.
- Human assurance that the connected peer is the intended nearby device.
- Minimization of discoverability and unsolicited request abuse.
- Safe handling of arbitrary received files.
- No secret keys stored in source code or logs.

2. Trust boundaries

Boundary	Threat	Control
Nearby radio/discovery	Impersonation / spoofed alias	Do not trust display name; verify session token on both devices.
Incoming requests	Spam / harassment	Rate limit, decline, block, Quick-Nod visibility window.
Local profile storage	Device/app data extraction	Private app storage, field encryption, Android Keystore-protected key, backup exclusion.
Transfer payload	Corruption / truncation	Size checks, SHA-256 manifest hashes, atomic finalization.
Received document	Malicious content	Never execute automatically; open through Android handlers; preserve MIME metadata.
Logs	Sensitive data leakage	Redact profile values, paths where sensitive, contact content and file content.
Dependencies	Compromised SDK/library	Pinned dependency management, SBOM/OSS register, update review.

3. Pair verification

A connection is not considered trusted merely because a Nearby endpoint connected. Nod shall present the same short authentication token/code on both devices and require user confirmation for the first connection session. The code is a human comparison aid, not a substitute for underlying transport cryptography.

4. Local encryption

- Generate a random AES key at first profile creation.
- Protect/wrap the key using Android Keystore capabilities appropriate to supported API levels.
- Use AES-GCM with unique nonces/IVs for encrypted profile records.
- Do not reuse GCM nonces with the same key.
- Do not store plaintext profile export files by default.
- Exclude sensitive Nod profile storage and keys from Android cloud/device-transfer backup where technically applicable.

5. File integrity

Sender computes or provides SHA-256 per transfer item. Receiver hashes the received temp content and compares before finalization. Mismatch results in INTEGRITY_FAILED and deletion/quarantine of the incomplete item.

6. Abuse controls

- Temporary discovery visibility by default.
- Separate device-connection consent from content-receipt consent.
- Block peer action available from request and history surfaces.
- Request cooldown/rate limit.
- No background pop-up that bypasses lock screen or Android background-launch rules.

7. Security testing

- Pairing MITM/alias-spoof simulation.
- Malformed Protobuf messages and oversized manifest fuzzing.
- Path traversal / hostile filenames.
- Interrupted payload and duplicate message replay.
- Hash mismatch.
- Low storage.
- Permission downgrade.
- Process death and app upgrade during pending transfer.
- Static analysis and dependency vulnerability scanning before each release.

8. Security release gate

No release without verification

The initial technical spike must prove peer verification, transfer integrity and interruption cleanup on multiple OEM devices before UI polish is treated as production work.